

CYBER SECURITY ENGINEER

E-Test MCQs with Solutions

NUST - Operations Research, Modelling & Simulation (ORMS)

Test Instructions:

- Total Questions: 50
- Time Allowed: 90 minutes
- Each question carries 2 marks
- Total Marks: 100
- Passing Marks: 70%
- Choose the best answer for each question

Section 1: Security Certifications & Fundamentals (10 Questions)

1. In CEH (Certified Ethical Hacker), what is the first phase of ethical hacking?

- A) Scanning
- B) Reconnaissance
- C) Gaining Access
- D) Maintaining Access

Answer: B) Reconnaissance

Explanation: Reconnaissance (Footprinting) is the first phase where attackers gather information about the target. This can be passive (OSINT) or active (direct interaction with target).

2. According to CompTIA Security+, which encryption algorithm is considered asymmetric?

- A) AES
- B) DES
- C) RSA
- D) Blowfish

Answer: C) RSA

Explanation: RSA is an asymmetric encryption algorithm using public and private key pairs. AES, DES, and Blowfish are symmetric algorithms using a single shared key.

3. In CySA+ terminology, what does TTPs stand for?

- A) Tools, Targets, and Protocols
- B) Tactics, Techniques, and Procedures
- C) Threats, Targets, and Practices
- D) Technology, Trends, and Protocols

Answer: B) Tactics, Techniques, and Procedures

Explanation: TTPs represent the behavior patterns of threat actors - their tactics (goals), techniques (methods), and procedures (specific implementations).

4. What is the primary purpose of the MITRE ATT&CK; framework?

- A) Vulnerability scoring
- B) Password management
- C) Knowledge base of adversary tactics and techniques
- D) Firewall configuration

Answer: C) Knowledge base of adversary tactics and techniques

Explanation: MITRE ATT&CK; is a globally-accessible knowledge base of adversary tactics and techniques based on real-world observations, used for threat modeling and detection.

5. Which protocol is used for secure email transmission in transit?

- A) SMTP
- B) STARTTLS
- C) POP3
- D) IMAP

Answer: B) STARTTLS

Explanation: STARTTLS upgrades plain text connections to encrypted TLS/SSL connections. While SMTP, POP3, and IMAP are email protocols, STARTTLS provides the encryption layer.

6. What does the 'Principle of Least Privilege' mean?

- A) Users should have maximum access for convenience
- B) Users should only have the minimum access necessary to perform their job
- C) Only administrators should have any privileges
- D) All users should have equal privileges

Answer: B) Users should only have the minimum access necessary to perform their job

Explanation: Least Privilege is a security principle that limits access rights to only what is strictly required, reducing the attack surface and potential damage from compromised accounts.

7. Which type of attack involves sending emails that appear to come from trusted sources?

- A) DDoS
- B) Phishing
- C) SQL Injection
- D) Man-in-the-Middle

Answer: B) Phishing

Explanation: Phishing is a social engineering attack where attackers impersonate legitimate entities via email to steal credentials, financial information, or install malware.

8. In the CIA triad, what does 'Integrity' refer to?

- A) Data is accessible when needed
- B) Data is kept confidential
- C) Data remains accurate and unaltered
- D) Data is properly backed up

Answer: C) Data remains accurate and unaltered

Explanation: Integrity ensures data accuracy and trustworthiness, preventing unauthorized modification. Confidentiality protects from unauthorized access, and Availability ensures access when needed.

9. What is a Zero-Day vulnerability?

- A) A vulnerability that exists for zero days
- B) A vulnerability with no known exploit
- C) A vulnerability unknown to the vendor with no patch available

D) A vulnerability that has been patched

Answer: C) A vulnerability unknown to the vendor with no patch available

Explanation: Zero-day vulnerabilities are security flaws exploited by attackers before vendors become aware and develop patches, making them extremely dangerous.

10. Which authentication factor is 'something you are'?

- A) Password
- B) Security token
- C) Fingerprint
- D) PIN

Answer: C) Fingerprint

Explanation: Biometric factors (fingerprint, iris scan, facial recognition) are 'something you are'. Passwords/PINs are 'something you know', and tokens are 'something you have'.

Section 2: SIEM Platforms (12 Questions)

11. In Splunk, what is the primary function of the Search Head?

- A) Stores indexed data
- B) Collects raw data from sources
- C) Handles search requests and distributes to indexers
- D) Forwards data to indexers

Answer: C) Handles search requests and distributes to indexers

Explanation: The Search Head manages user search requests, coordinates searches across indexers, and presents results. Indexers store data, while Forwarders collect it.

12. Which Splunk Processing Language (SPL) command is used to filter results?

- A) stats
- B) where
- C) eval
- D) table

Answer: B) where

Explanation: The 'where' command filters search results based on specified conditions. 'stats' performs statistical operations, 'eval' calculates expressions, and 'table' formats output.

13. In IBM QRadar, what is an 'Offense'?

- A) A single security event
- B) A correlated security incident requiring investigation
- C) A system log entry
- D) A network packet

Answer: B) A correlated security incident requiring investigation

Explanation: QRadar Offenses are security incidents created when events match correlation rules, indicating potential security threats that require analyst attention.

14. What protocol does ArcSight primarily use for event collection?

- A) SNMP
- B) CEF (Common Event Format)
- C) SMTP
- D) FTP

Answer: B) CEF (Common Event Format)

Explanation: ArcSight uses CEF as a standardized format for log messages, enabling consistent parsing and correlation of events from diverse sources.

15. In LogRhythm, what is the purpose of the AI Engine?

- A) Data storage
- B) Log collection
- C) Real-time correlation and rule processing
- D) Report generation

Answer: C) Real-time correlation and rule processing

Explanation: LogRhythm's AI Engine performs real-time event correlation, applies detection rules, and generates alarms based on security logic and threat intelligence.

16. Which Splunk command creates summary statistics?

- A) search
- B) stats
- C) index
- D) source

Answer: B) stats

Explanation: The 'stats' command performs statistical operations like count, sum, average, and grouping, essential for data analysis and metrics generation.

17. In QRadar, what is the maximum severity level for offenses?

- A) 5
- B) 7
- C) 10
- D) 100

Answer: C) 10

Explanation: QRadar uses a severity scale of 1-10, with 10 being the most critical. Severity is calculated based on relevance, credibility, and asset importance.

18. What is the primary benefit of using normalized data in SIEM?

- A) Faster data collection
- B) Consistent format enabling effective correlation across sources
- C) Reduced storage requirements
- D) Better encryption

Answer: B) Consistent format enabling effective correlation across sources

Explanation: Normalization converts diverse log formats into a common schema, enabling SIEMs to correlate events from different sources and detect complex attack patterns.

19. In Splunk, what is a 'sourcetype'?

- A) The server that generated the log
- B) The category defining the data structure and format
- C) The index where data is stored

D) The network protocol used

Answer: B) The category defining the data structure and format

Explanation: Sourcetype identifies the data format (e.g., access_combined, syslog, json), determining how Splunk parses and indexes the data.

20. What is the purpose of a SIEM correlation rule?

- A) Compress log data
- B) Detect patterns across multiple events indicating security incidents
- C) Encrypt sensitive logs
- D) Delete old logs

Answer: B) Detect patterns across multiple events indicating security incidents

Explanation: Correlation rules analyze relationships between events over time to identify complex attack patterns that single events wouldn't reveal.

21. In LogRhythm, what is a 'Deployment'?

- A) Software update process
- B) Logical grouping of devices and log sources
- C) Security incident
- D) Backup operation

Answer: B) Logical grouping of devices and log sources

Explanation: Deployments in LogRhythm organize log sources and devices into logical groups for management, monitoring, and analysis purposes.

22. Which metric indicates SIEM performance efficiency?

- A) Events Per Second (EPS)
- B) CPU temperature
- C) Network bandwidth
- D) Disk space only

Answer: A) Events Per Second (EPS)

Explanation: EPS measures the number of events a SIEM can process per second, indicating its capacity and performance. Higher EPS means handling larger data volumes.

Section 3: Threat Intelligence & Threat Hunting (10 Questions)

23. What is the primary goal of threat hunting?

- A) Wait for alerts to investigate
- B) Proactively search for threats that evaded existing defenses
- C) Configure firewalls
- D) Patch vulnerabilities

Answer: B) Proactively search for threats that evaded existing defenses

Explanation: Threat hunting is proactive - analysts actively search for advanced threats and indicators of compromise that automated systems may have missed.

24. What is an Indicator of Compromise (IoC)?

- A) A system performance metric
- B) Evidence that a system has been breached or infected
- C) A firewall rule
- D) A backup file

Answer: B) Evidence that a system has been breached or infected

Explanation: IoCs are forensic artifacts (IP addresses, file hashes, URLs, registry keys) indicating potential intrusions, used for detection and investigation.

25. Which framework categorizes threat intelligence into Strategic, Tactical, and Operational?

- A) NIST CSF
- B) Intelligence types framework
- C) OSI Model
- D) TCP/IP Stack

Answer: B) Intelligence types framework

Explanation: Threat intelligence is categorized by purpose: Strategic (high-level trends for leadership), Tactical (TTPs for defenders), Operational (specific campaign details).

26. What does STIX stand for in threat intelligence?

- A) Security Threat Intelligence Exchange
- B) Structured Threat Information Expression
- C) System Threat Identification XML
- D) Standard Threat Intelligence Export

Answer: B) Structured Threat Information Expression

Explanation: STIX is a standardized language for describing cyber threat information, enabling automated sharing and analysis across organizations and tools.

27. What protocol does TAXII use for sharing threat intelligence?

- A) FTP
- B) HTTPS
- C) Telnet
- D) SMTP

Answer: B) HTTPS

Explanation: TAXII (Trusted Automated Exchange of Intelligence Information) uses HTTPS for secure, standardized exchange of cyber threat intelligence in STIX format.

28. In the Diamond Model of Intrusion Analysis, which element is NOT a core component?

- A) Adversary
- B) Capability
- C) Infrastructure
- D) Timeline

Answer: D) Timeline

Explanation: The Diamond Model's four core elements are Adversary, Capability, Infrastructure, and Victim. Timeline is a meta-feature, not a core component.

29. What is the Pyramid of Pain used for in threat intelligence?

- A) Ranking vulnerabilities by severity
- B) Showing difficulty for attackers when defenders detect different IoC types
- C) Measuring network latency
- D) Organizing firewall rules

Answer: B) Showing difficulty for attackers when defenders detect different IoC types

Explanation: The Pyramid of Pain ranks IoCs by how painful it is for attackers to change them - from easy (hash values) to difficult (TTPs), guiding defense priorities.

30. What is a 'living off the land' technique?

- A) Using physical hardware only
- B) Attackers using legitimate system tools to avoid detection
- C) Outdoor hacking
- D) Using only open-source software

Answer: B) Attackers using legitimate system tools to avoid detection

Explanation: Living off the Land (LotL) attacks use built-in system tools (PowerShell, WMI, PsExec) for malicious purposes, making detection challenging.

31. Which platform aggregates threat intelligence from multiple sources?

- A) DNS server
- B) Threat Intelligence Platform (TIP)
- C) Web browser

D) Email client

Answer: B) Threat Intelligence Platform (TIP)

Explanation: TIPs aggregate, normalize, and enrich threat intelligence from multiple feeds, enabling contextualized analysis and automated response actions.

32. What is the primary purpose of a YARA rule?

- A) Network routing
- B) Pattern matching to identify malware families
- C) Firewall configuration
- D) Password management

Answer: B) Pattern matching to identify malware families

Explanation: YARA rules use pattern matching to classify and identify malware based on textual or binary patterns, widely used in malware analysis and threat hunting.

Section 4: Network Forensics & Incident Response (10 Questions)

33. Which tool is primarily used for packet capture and analysis?

- A) Nmap
- B) Wireshark
- C) Metasploit
- D) Nessus

Answer: B) Wireshark

Explanation: Wireshark is the industry-standard tool for capturing and analyzing network traffic at the packet level, essential for network forensics and troubleshooting.

34. In network forensics, what is 'NetFlow'?

- A) A firewall brand
- B) Network protocol for collecting IP traffic information
- C) A VPN technology
- D) An antivirus program

Answer: B) Network protocol for collecting IP traffic information

Explanation: NetFlow records metadata about network flows (source, destination, ports, protocols, bytes) without full packet capture, enabling efficient traffic analysis.

35. Which phase comes first in the Incident Response lifecycle?

- A) Containment
- B) Preparation
- C) Detection and Analysis
- D) Recovery

Answer: B) Preparation

Explanation: NIST's IR lifecycle starts with Preparation (tools, training, procedures), followed by Detection/Analysis, Containment/Eradication/Recovery, and Post-Incident Activity.

36. What is the purpose of a chain of custody in digital forensics?

- A) Encrypt evidence
- B) Document evidence handling to maintain integrity and admissibility
- C) Delete evidence
- D) Compress files

Answer: B) Document evidence handling to maintain integrity and admissibility

Explanation: Chain of custody tracks who collected, accessed, and stored evidence, ensuring its integrity and legal admissibility by preventing tampering allegations.

37. Which command-line tool can capture network packets on Linux?

- A) ping
- B) tcpdump
- C) netstat
- D) traceroute

Answer: B) tcpdump

Explanation: tcpdump is a powerful command-line packet analyzer for Unix-like systems, capturing and displaying network packets matching specified criteria.

38. What does 'volatile data' mean in forensics?

- A) Data that is encrypted
- B) Data that is lost when power is removed (RAM, cache)
- C) Data on hard drives
- D) Backup data

Answer: B) Data that is lost when power is removed (RAM, cache)

Explanation: Volatile data (RAM contents, running processes, network connections) disappears when systems power off, requiring immediate collection during investigations.

39. What is a Memory dump in incident response?

- A) Deleting memory
- B) Snapshot of RAM contents for analysis
- C) Storage backup
- D) Network traffic log

Answer: B) Snapshot of RAM contents for analysis

Explanation: Memory dumps capture RAM contents, revealing running malware, encryption keys, passwords, and recent activities invisible in disk analysis.

40. Which Wireshark filter shows only HTTP traffic?

- A) tcp.port == 80
- B) http
- C) ip.proto == http
- D) Both A and B

Answer: D) Both A and B

Explanation: Both 'http' (protocol filter) and 'tcp.port == 80' (port filter) can display HTTP traffic. The protocol filter is more accurate as HTTP can use other ports.

41. What is the primary purpose of a PCAP file?

- A) System configuration
- B) Store captured network packet data
- C) Encrypt communications

D) Manage passwords

Answer: B) Store captured network packet data

Explanation: PCAP (Packet Capture) files store raw network traffic data captured by tools like Wireshark or tcpdump, enabling offline analysis and evidence preservation.

42. In incident response, what does 'Eradication' involve?

- A) Detecting the incident
- B) Removing the threat and its artifacts from the environment
- C) Monitoring for recurrence
- D) Initial preparation

Answer: B) Removing the threat and its artifacts from the environment

Explanation: Eradication removes malware, closes backdoors, and eliminates threat actor access, following containment and preceding recovery in the IR lifecycle.

Section 5: Firewall & Network Security (8 Questions)

43. What type of firewall operates at the application layer?

- A) Packet filtering firewall
- B) Stateful inspection firewall
- C) Next-Generation Firewall (NGFW)
- D) Circuit-level gateway

Answer: C) Next-Generation Firewall (NGFW)

Explanation: NGFWs operate up to Layer 7, providing deep packet inspection, application awareness, IPS, and advanced threat protection beyond traditional firewalls.

44. What is the default action recommended for firewall rules?

- A) Allow all traffic
- B) Deny all (implicit deny)
- C) Log only
- D) Random decision

Answer: B) Deny all (implicit deny)

Explanation: Implicit deny (default deny) is a security best practice - blocking all traffic except explicitly allowed, following the principle of least privilege.

45. Which firewall feature maintains information about active connections?

- A) Packet filtering
- B) Stateful inspection
- C) Proxy service
- D) NAT

Answer: B) Stateful inspection

Explanation: Stateful firewalls track connection states (TCP handshakes, sessions), allowing only packets belonging to established connections, providing better security than stateless filtering.

46. What does DMZ stand for in network security?

- A) Demilitarized Zone
- B) Data Management Zone
- C) Dynamic Memory Zone
- D) Digital Monitoring Zone

Answer: A) Demilitarized Zone

Explanation: A DMZ is a perimeter network segment isolating external-facing services (web servers, email) from internal networks, providing an additional security layer.

47. Which protocol does IPSec use for encryption and authentication?

- A) ESP (Encapsulating Security Payload)
- B) HTTP
- C) FTP
- D) SMTP

Answer: A) ESP (Encapsulating Security Payload)

Explanation: IPSec uses ESP for encryption and data integrity, and AH (Authentication Header) for authentication. ESP provides confidentiality, authentication, and integrity.

48. What is the main difference between IDS and IPS?

- A) IDS detects and alerts; IPS detects and actively blocks threats
- B) IDS is hardware; IPS is software
- C) IDS is faster than IPS
- D) No difference

Answer: A) IDS detects and alerts; IPS detects and actively blocks threats

Explanation: IDS (Intrusion Detection System) passively monitors and alerts, while IPS (Intrusion Prevention System) actively blocks threats inline, preventing attacks in real-time.

49. Which port does HTTPS use by default?

- A) 80
- B) 443
- C) 8080
- D) 22

Answer: B) 443

Explanation: HTTPS (HTTP Secure) uses port 443 for encrypted web traffic via SSL/TLS. HTTP uses 80, SSH uses 22, and 8080 is an alternative HTTP port.

50. What technology allows multiple internal devices to share a single public IP?

- A) DNS
- B) DHCP
- C) NAT (Network Address Translation)
- D) SNMP

Answer: C) NAT (Network Address Translation)

Explanation: NAT translates private IP addresses to public IPs, conserving IPv4 addresses and hiding internal network structure. PAT (Port Address Translation) enables sharing one public IP.

Quick Answer Key

Q#	Answer	Q#	Answer	Q#	Answer
1	B	18	B	35	B
2	C	19	B	36	B
3	B	20	B	37	B
4	C	21	B	38	B
5	B	22	A	39	B
6	B	23	B	40	D
7	B	24	B	41	B
8	C	25	B	42	B
9	C	26	B	43	C
10	C	27	B	44	B
11	C	28	D	45	B
12	B	29	B	46	A
13	B	30	B	47	A
14	B	31	B	48	A
15	C	32	B	49	B
16	B	33	B	50	C
17	C	34	B		

Scoring Guide:

- 90-100 (45-50 correct): Excellent - Strong candidate
- 70-89 (35-44 correct): Good - Meets requirements
- 50-69 (25-34 correct): Average - Needs improvement
- Below 50 (<25 correct): Below expectations

Good luck with your preparation!